

Codex Enterprise Rollout Design

Linton Labs ·
Engineering
Leadership
& Platform S
takeholders ·
Rollout
Review

SAFE BY
DEFAULT

LOW
FRICTION
ADOPTION

AUDITABLE &
GOVERNABLE

RECOVERABLE

DECISION

GUARDRAIL

RECOVERY

Plain text = context / how-to (no tribal knowledge assumed)

■ Surface Strategy

DECISION: Codex App is the default for billing/backend teams; IDE extension for frontend; CLI for CI pipelines only.

- Codex App gives the fullest agentic loop with file browser, terminal, and PR creation in one place.

DECISION: Worktrees are mandatory for multi-file refactors; optional for single-file edits.

- Worktrees prevent mid-task conflicts on shared branches. Git worktree add creates one.

DECISION: Cloud tasks are required for jobs running longer than 30 min; forbidden in air-gapped environments.

DECISION: Windows machines run unelevated sandbox mode by default. Elevated mode requires explicit IT approval.

- WSL is the fallback if elevated setup is blocked by policy. Run wsl --install in PowerShell as admin.

■ Model Strategy

DECISION: claude-sonnet-4-6 is the default model for all work — best cost-to-quality ratio for everyday tasks.

DECISION: API-key workflows must pin to the latest stable model string; rotate the key quarterly.

- Pinning avoids silent capability changes mid-project. Update the string in config.toml under [model].

DECISION: Escalate to full reasoning effort only for architecture decisions and security reviews — it is slower and costs more.

- Spark model is approved for ultra-low-latency loops (linting, autocomplete) only. It requires tighter task scope and explicit output validation because it skips extended reasoning.

■ Context Continuity & Recovery Playbook

DECISION: Checkpoints are triggered after every significant decision, file write, or passing test run.

- A checkpoint is a saved thread summary exported to checkpoints/.md in the repo root.

DECISION: Compact the context when usage exceeds 70 %: summarise decisions made, preserve open questions verbatim.

RECOVERY: Failed attempt: restore the last checkpoint (codex restore --latest) and retry with a narrower task scope.

RECOVERY: Drift detected (agent repeating or contradicting itself): stop, re-read AGENTS.md, then resume from the last clean checkpoint rather than continuing forward.

RECOVERY: Surface switch (e.g. moving from Codex App to CLI mid-task): export thread summary first (codex export --thread), then import it on the new surface (codex import) before continuing.

RECOVERY: Restarting a thread: paste the last checkpoint summary as the first user message so the agent has full context without relying on session history.

■ Governance Bundle

DECISION: config.toml lives in each repo root. Org-wide defaults are pushed via the internal codex-template repo — do not hand-edit individual repos.

- config.toml controls: model, sandbox mode, internet access, and secret injection. Keys are documented inline in the template.

DECISION: Every repo must have an AGENTS.md that includes: verification commands to run before marking done, PR review checklist, and an explicit done definition.

GUARDRAIL: GUARDRAIL — .rules file must allowlist src/ and tests/ for read/write; must block: rm -rf, git push --force, and curl to any external host not on the approved list.

- Standard skills shared across all teams: secure-pr-review, ci-fix-loop, release-notes. Clone from the skills/ folder in codex-template.

■ Cloud Environment Policy

DECISION: Internet access is OFF by default for all cloud tasks. Enable per-repo only for known package registries by adding an allowlist entry to config.toml.

GUARDRAIL: GUARDRAIL — Secrets must be injected via environment variables only. Never hardcode secrets in config.toml, AGENTS.md, or any committed file.

GUARDRAIL: GUARDRAIL — Sandbox mode must remain active for all cloud tasks. Disabling it requires a written exception approved by the platform team.

- Setup script (scripts/codex-setup.sh in each repo) installs deps and warms Docker layer caches before the agent starts — run it on first provisioning and after any major dep change.

■ Integrations

DECISION: GitHub code review: manual @codex review is required for all PRs in the first 30 days. Automatic review unlocks for the billing platform repo only after the pilot period ends with no P0 incidents.

- To trigger a manual review: comment @codex review on the PR. Codex will respond with a structured summary and inline comments within 5 minutes.

GUARDRAIL: GUARDRAIL — Slack integration may post summaries to approved channels only. Codex must not send DMs, create channels, or post to channels outside the allowlist in config.toml.

- Linear: Codex may update task status and add comments. It must not create or delete issues without a human approving the action in the Linear UI first.

■ Admin & Monitoring Plan

DECISION: Local Codex is enabled via SSO login — no separate provisioning needed. Cloud tasks require membership in the codex-cloud-users RBAC group, which IT provisions on request via the #platform-eng Slack channel.

- Governance signals to track: (1) token usage per team via the Anthropic admin dashboard — analytics tab; (2) tool-call logs per repo — compliance tab; (3) error rates on the SRE dashboard under codex-errors.
- Support runbook: (a) Approval delays → ping #platform-eng with the PR link. (b) Sandbox errors → check that the unelevated flag is set in config.toml and that the Windows build is 22H2+. (c) Missing access → verify RBAC group membership and org entitlement in the admin console.

GUARDRAIL: GUARDRAIL — Windows onboarding checklist (run before first use): confirm elevated prerequisites met, verify active sandbox mode, confirm correct sign-in path (SSO not personal account), check org entitlements in the Anthropic admin console.